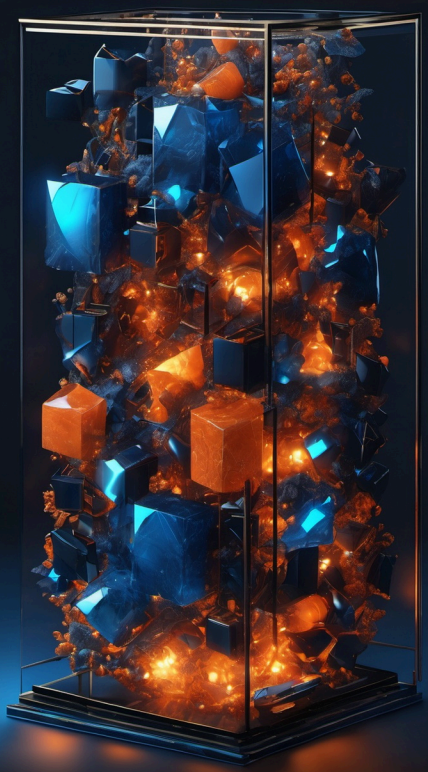
A SMALL BUSINESS GUIDE

# THE HIDDEN RISK OF CONNECTED APPS



## OAuth Permissions, Integrations, and Data Access

A Small Business Guide to Protecting Email, Cloud Storage, and Customer Information

ZIRLANDIA MILKOVIC

A SMALL BUSINESS GUIDE

# THE HIDDEN RISK OF CONNECTED APPS

OAuth Permissions, Integrations, and Data Access: A Small Business Guide to Protecting Email, Cloud Storage, and Customer Information

ZIRLANDIA MILKOVIC

**The Hidden Risk of Connected Apps**
OAuth Permissions, Integrations, and Data Access: A Small Business Guide to Protecting Email, Cloud Storage, and Customer Information

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: late October 2026.

This book is practical guidance, not legal, data-protection or IT-security advice.

Cover and chapter artwork generated with AI tools and edited by the author. All named businesses, people and apps in the examples are fictional unless a source is cited.

# Contents

**START HERE**

Before You Begin ..... 4
Who This Book Is For ..... 4
How to Use This Guide ..... 5
Introduction: The Quiet Door ..... 6

**CHAPTERS**

1. The Button That Opens the Door ..... 8
2. What Is a Connected App? ..... 12
3. What Are You Actually Allowing? ..... 17
4. Five Connected-App Risks Small Businesses Overlook ..... 21
5. The Difference Between Useful Access and Excessive Access ..... 26
6. How Connected Apps Become a Security Problem ..... 30
7. How to Review Connected Apps ..... 35
8. Revoking Access Without Breaking Your Business ..... 39
9. Connected Apps and GDPR ..... 42
10. Build a Simple Connected-App Policy ..... 46
11. The Quarterly Connected-App Audit ..... 48
12. Your 30-Day Connected-App Security Plan ..... 52

**CLOSING**

Conclusion: Know Who Has the Keys ..... 56

**APPENDICES**

Appendix A: Quarterly Connected-App Audit Worksheet ..... 57
Appendix B: Connected-App Inventory Template ..... 60
Appendix C: Permission Risk Assessment ..... 62
Appendix D: New Integration Approval Form ..... 64
Appendix E: Emergency Access Review Checklist ..... 66
Appendix F: Small Business Connected-App Policy ..... 68
Appendix G: Glossary ..... 70
Appendix H: Knowledge Check ..... 72

**BACK MATTER**

Appendix I: Sources and Further Reading ..... 74
About the Author ..... 76

# Before You Begin

**Important notice.** This book is practical guidance for small businesses. It is not legal, data-protection, cyber-insurance or IT-security advice, and it is not a substitute for advice from a qualified professional who knows your business and your systems. Software changes constantly. Menu names, permission names and default settings differ between providers and are updated without notice. Where this book describes a setting, it says which official page it was checked against and when. Please confirm the current screen in front of you before you act.

**What is fact, what is advice, and what is made up.** The book keeps four kinds of statement apart:

- **Verified facts** come from a numbered source in *Sources and Further Reading* at the back, for example [1]. They were read in late October 2026.
- **Recommendations** are the author's practical advice. They are proportionate suggestions, not requirements, and a checklist cannot guarantee security.
- **Fictional scenarios** are marked *Fictional example*. Every business, person and product in them is invented. Any resemblance to a real company, person or product is coincidental.
- **Legal points** are explained in general terms and nearly always depend on context. Chapter 9 says more.

**About product names.** Real products are named only where an official provider document is being cited. Nothing here claims that any real product is unsafe. The fictional apps in the examples (MailMate, SlotPilot and so on) do not exist.

**About numbers.** There are almost no statistics in this book, on purpose. Where a figure appears, it comes from a named source.

**Research cut-off.** Sources were reviewed in late October 2026.

© 2026 *Zirlandia Milkovic. All rights reserved.*

# Who This Book Is For

You do not need to be technical to use this book. You need to be responsible for, or curious about, the business tools your organisation relies on.

It is written mainly for:

- **owners and directors** of small and medium-sized businesses;
- **freelancers, consultants and independent professionals** who hold client information in their own accounts;
- **marketing agencies and e-commerce businesses** that connect many tools to many client accounts;
- **start-ups and small software-as-a-service (SaaS) companies** that both use integrations and offer them;
- **office managers and operations teams**, who are often the people quietly asked to "just connect it";
- **anyone who handles customer data** in a CRM, a shared drive, a mailbox or a helpdesk;
- **European and UK businesses** that want to understand the data-protection side of letting another company's software into their systems.

You should already know how to use common business software. You do not need to know what OAuth is. The book explains it, and every technical term is defined the first time it appears and again in the glossary in Appendix G.

**A note on British and European readers.** The book uses British English and is written with UK and European small businesses in mind. Where the UK GDPR and the EU GDPR are similar, the text says "GDPR". Where UK and EU practice differ, it says so, or points you to the right regulator: the Information Commissioner's Office (ICO) in the UK, or your national supervisory authority in the EU.

# How to Use This Guide

You can read this book in two ways.

**If you have an afternoon:** read Chapters 1 to 6 to understand what you are dealing with, then do the review in Chapters 7 and 8. The quarterly audit in Chapter 11 will then make sense, and the worksheets in Appendices A and B are ready to print.

**If you have thirty minutes:** go straight to Chapter 11 and Appendix A. They stand alone. Come back to the earlier chapters when a term or a decision puzzles you.

**The signature tool.** The *Quarterly Connected-App Audit Worksheet* in Appendix A is the heart of the book. It is a single set of pages that any member of staff can complete, without special software, in roughly 30 to 60 minutes. Everything else in the book exists to make that worksheet easier to complete and the decisions on it easier to defend.

**The rule of the book.** Look for the dark boxes headed **The rule**. They hold one idea each, in a sentence you can repeat to a colleague.

**Each chapter ends the same way**: a short list of practical takeaways or actions. If you only have time to do the actions, do those.

**The appendices are meant to be copied.** The worksheets, forms, checklists and policy in Appendices A to F are written so that you can paste them into a document or spreadsheet and edit the placeholders in square brackets. Please adapt them. A template that fits your business is worth more than one followed to the letter.

# Introduction: The Quiet Door

Think of the last time you connected one business tool to another. Perhaps a scheduling page needed to see your calendar. Perhaps an AI note-taker asked to join your meetings, or an invoicing tool wanted to read a folder. A window opened, it showed your company logo and the words **Allow**, and you clicked.

It took a few seconds. It saved hours. And nobody wrote it down.

Multiply that by every person in your business, every month, for several years. Some of those connections are still in daily use. Some were a trial that nobody cancelled. Some were set up by a freelancer who left in 2023. Some belong to a tool that has since been sold to another company. Each one may still be able to do whatever it was permitted to do on the day somebody clicked: read mail, open files, update customer records, send messages in your name.

None of this means that connected apps are bad. They are one of the reasons a ten-person business can work like a hundred-person one. Nor is the technology behind them, called OAuth, insecure. It was designed so that you do not have to hand over your password. [1]

But **OAuth is a way of granting access, not a guarantee that the party receiving access is trustworthy or careful**. The decision about whether to grant it, and how much, still rests with a person, usually a busy one, looking at a short screen of text. And access, once granted, tends to outlive the reason it was granted.

This book is about closing that gap. It does not ask you to stop using connected apps. It gives you a way to know which ones you have, what each one can reach, who is responsible for it, and whether it is still needed.

**What this book is not.** It is not a general course in passwords, phishing or antivirus, and it does not try to cover your whole security or GDPR programme. Those matter, and the UK National Cyber Security Centre (NCSC) has free guidance for small organisations on the basics. [11] This book does one narrow job and does it in detail: **seeing, judging and tidying the access that other people's software has to your business data.**

CHAPTER 1

# The Button That Opens the Door



**Fictional example.** *Meridian Lettings is a ten-person estate agency. Nothing in this story is real.*

On a busy Monday, Dana, the office manager, is drowning in email. A colleague mentions a tool called MailMate (fictional) that sorts an inbox, drafts replies and summarises long threads. Dana searches for it, finds a free trial, and clicks **Sign in with Google**.

A window appears. It lists what MailMate would like to do: *read, compose, send and permanently delete all your email*. Dana is on her way to a viewing. The window has a blue button and a grey one. She clicks the blue one.

The tool works well. Her inbox is tidy by lunchtime. She tells two colleagues, who connect it too. Nobody tells the owner. Nobody notes it down. The free trial ends, the card on file is never charged because it was never added, and everyone forgets about MailMate.

Eleven months later, MailMate's developer sells the product to another company. The new owner changes the privacy terms. The old connections are still in place, still able to do exactly what the blue button allowed.

Nothing dramatic has happened in this story. No one was hacked. No one was careless in a way most of us have not been. And yet by the end of it, an organisation that handles tenancy agreements, ID documents and bank details has a third party that can read and send from three of its mailboxes, and nobody in the business knows.

That is the hidden risk this book is about: **not a break-in, but an open door that nobody remembers opening.**

## Why connected apps are everywhere

Modern business software is built to connect. Your calendar talks to your video-call tool. Your online shop talks to your accounting package. Your helpdesk pulls customer details from your CRM (customer relationship management system, the database of your customers and deals). A growing number of AI assistants ask to read your inbox, your documents or your meeting recordings so that they can summarise them.

The reasons are good ones:

- **Time.** Connected tools remove re-typing and copy-and-paste.
- **Choice.** Small businesses can assemble the tools they like instead of buying one large package.
- **Ease.** A one-click connection avoids sharing passwords, which is better than the alternative.
- **Price.** Many connections are free or cheap, so they bypass purchase approval altogether.

That last point matters. A connection that costs nothing needs no invoice, and no invoice means nothing for finance to notice.

## What actually happens when someone clicks "Allow"

Behind the button is an **authorisation**. Simplified, three parties are involved:

1. **You** (or your employee), who own or can reach the data;
2. **the app**, which wants to use it;
3. **the platform** that holds the data, such as your email or cloud-storage provider.

When you click **Allow**, you are telling the platform: *this app may do these specific things with my data, on my behalf, until I say otherwise*. The platform then issues the app a digital credential, called a **token**, which the app presents each time it asks for something. You never give the app your password. That is the good part of the design. [1]

The less comfortable part is the phrase *until I say otherwise*. Many authorisations have no end date. Some can be renewed automatically in the background for as long as the app wishes. Chapter 2 explains how.

## Installed is not the same as authorised

The distinction below sounds technical but is the most useful single idea in this book.

| | Installed | Authorised |
|---|---|---|
| What it means | Software is on a device or added to your workspace | Software has been *given permission* to act on your data |
| Who sees it | Often an IT person, or whoever installed it | Often nobody; it lives in an account setting |
| What removing it does | May leave the permission behind | Stops the app reaching your data through that route |
| Typical example | A browser extension on a laptop | A scheduling tool allowed to read your calendar |

An app can be authorised without ever being installed, because it runs on someone else's server. It can also be installed and deleted from a laptop while the authorisation it created stays active. If you only look at what is installed, you will miss what is authorised.

## Why review instead of trust?

Reviewing is not an accusation. Most connected apps are run by legitimate companies doing what they say. The reasons to review are practical:

- **Needs change.** Last year's essential tool may be unused today.
- **Companies change.** A product can be sold, merged, closed or compromised.
- **People change.** The employee who approved a connection may have left.
- **Permissions change.** Apps can ask for more access later, and the settings you saw on day one may not be those in force now.
- **Memory fails.** Nobody holds an accurate list of connections in their head.

> **The rule.** Treat every connection like a key you have handed out: you should be able to say who holds it, what it opens, why they have it and when you last checked.

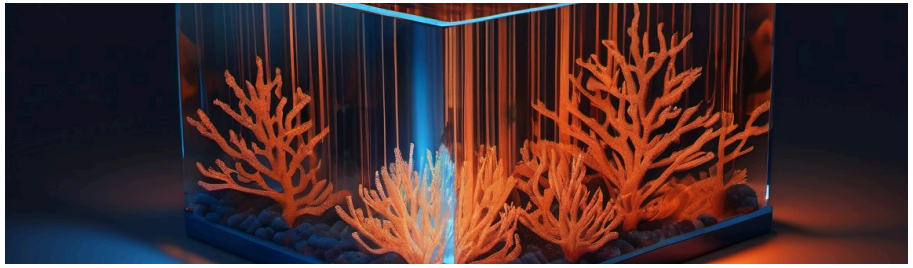
## Takeaways

- A connected app is a **standing permission**, not a one-off action. It continues until somebody ends it.

- **Installed and authorised are different things.** Review authorisations, not only software.
- You do not need to distrust every app. You need a **list, an owner and a review date** for each.

CHAPTER 2

# What Is a Connected App?



Let us build the vocabulary, one plain-English step at a time. You will meet each term again in the glossary (Appendix G).

## Third-party applications

A **third-party application** is software made by someone other than you and the provider of the platform it connects to. Your email provider is the first party, your business is the second, and the scheduling tool is the third.

"Third-party" is not an insult. It simply tells you that a different organisation, with its own staff, systems, contracts and risks, now has a route to your data.

## Integrations and automation tools

An **integration** is a connection between two pieces of software so that they exchange information. An **automation platform** is a tool whose whole purpose is to build such connections: *when a form is submitted, create a customer record, send a welcome email and add a row to a spreadsheet.* Automation tools are powerful because they connect to many of your systems at once. They come back in Chapter 4.

## APIs

An **API** (application programming interface) is the set of defined requests a piece of software allows other software to make. If a restaurant is a system, the API is the menu and the waiter: you can only order what is on the menu, through the proper channel. Integrations use APIs. Permissions decide which parts of the "menu" an app may order from.

## OAuth: the framework behind the button

**OAuth 2.0** is an internet standard for **delegated authorisation**: it lets you allow an application to access your data on another service *without* giving it your password. [1] It is the technology behind most "Sign in with…" and "Allow access" screens.

Three honest points about OAuth:

1. **It is a framework, not a certificate.** It describes how access is requested, granted and used. It says nothing about whether the app asking is trustworthy.
2. **Its security depends on implementation.** Standards bodies publish up-to-date security advice for those who build with it, including the IETF's *Best Current Practice for OAuth 2.0 Security*. [2] A well-built app follows that advice. You cannot see from outside whether one has.
3. **What an app can actually do** depends on the permissions granted, how the provider enforces them, how the app is built and what controls your administrator has set.

## Authentication versus authorisation

These two words are constantly confused.

- **Authentication** answers *who are you*? Typing a password or approving a prompt on your phone is authentication.
- **Authorisation** answers *what are you allowed to do*? Being allowed to read a folder but not delete it is authorisation.

"Sign in with Google" sounds like authentication, and often it is only that. Google's own help page explains that signing in with Google on a supporting app can share just your basic profile (name, email address, profile picture), while other requests ask to view or copy your data, or to manage it by editing, creating and deleting. [4] The two can look similar on screen. **Always read which one is being asked for.**

## Permission scopes

A **scope** is a named permission, such as "read your calendar" or "see, edit, create and delete your files". The platform decides what each scope means. [1] The app asks for a list; you (or an administrator) approve or refuse. Platforms can grant less than the app asked for.

Scopes are where the real risk decisions live. A scope that reads one calendar is very different from one that deletes any file you can reach.

## Access tokens and refresh tokens

After you click Allow, the platform issues two credentials, simplified here:

- An **access token**, which the app shows to the platform with each request. It usually works for a short time.
- A **refresh token**, which lets the app obtain new access tokens without bothering you again. [1]

The refresh token is the reason an authorisation can continue for months or years without you seeing another prompt. It is also the reason that **stealing or misusing a token can give a third party the same access as the app**, without a password and sometimes without any new sign-in prompt. Security standards recommend protecting tokens and restricting what each token can do. [2][3]

## Delegated access and application-level access

Microsoft's documentation distinguishes two arrangements that matter to you. [7]

- **Delegated access**: the app acts *on behalf of a signed-in user*. Microsoft states that it cannot reach anything the user could not reach.
- **Application (app-only) access**: the app acts *as itself*, with no user signed in, which is typical for background automation and backups. Microsoft's example is that an app granted the Microsoft Graph `Files.Read.All` application permission can read any file in the tenant (your organisation's account space). In general, only an administrator can consent to application permissions.

For a business owner the practical lesson is this: **app-level access is usually broader, and it needs a closer look.** Other providers use different names for similar ideas, so ask your provider how its own controls work.

## Personal and organisational accounts

The same app can behave differently depending on whose account it joins.

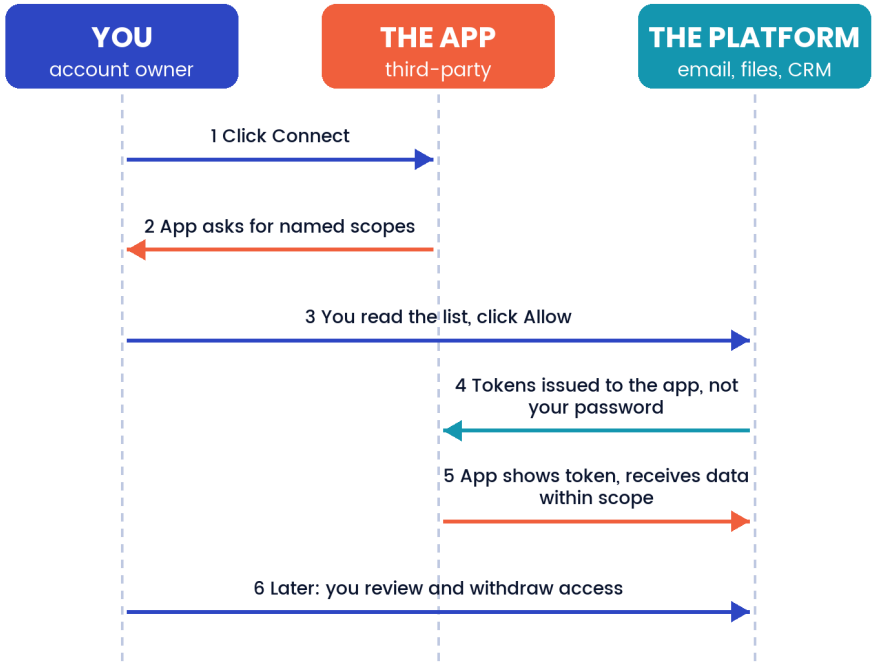
- On a **personal account** (a free Gmail address, say), the individual decides, and nobody else in the business can see it.

- On an **organisational account** (a Google Workspace or Microsoft 365 tenant), an administrator may be able to see, block, allow or limit apps. Google, for example, lets Workspace administrators set apps as trusted, limited, restricted to specific data or blocked, and can list apps that have accessed data. [5] Microsoft lets administrators restrict who may consent. [7]

Two warnings follow. Staff sometimes use **personal accounts for work**, which puts business data outside any administrator's view. And a controls-rich organisational account does nothing unless **someone has switched the controls on and looks at them**.

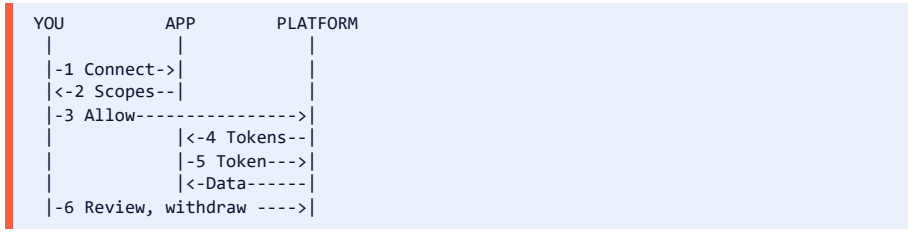
## A picture: who talks to whom

Think of the platform as a building with many rooms. The app is a visitor, the platform's reception is the authorisation server, and the token is a visitor pass.




The authorisation journey, simplified. The password never goes to the app; the token does.

The same journey as a text diagram (numbers match the figure):




## The key analogy

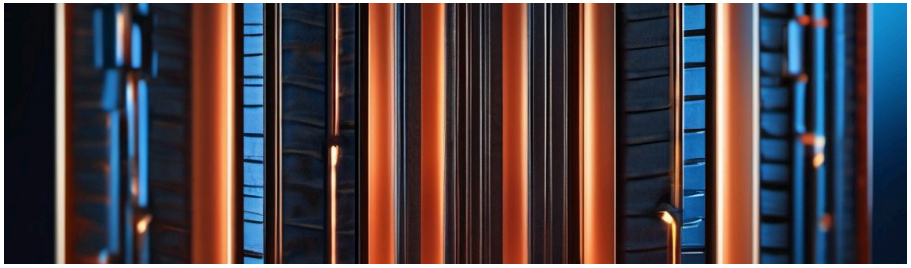
Imagine handing a cleaner a key. A good arrangement is a key to the front door only, valid for Tuesday mornings, with the cleaner's name written down. A poor arrangement is a master key to every room and the safe, with no name and no end date. Both are "giving the cleaner a key". **Scopes decide which doors the key opens, tokens are the key itself, and your review is how you notice the master keys.**

## Takeaways

- **OAuth lets you grant access without sharing a password.** It does not tell you whether the app is trustworthy.
- **Scopes are the part to read.** Different scopes can mean very different power.
- **Tokens keep working** until access is revoked or expires, so a stolen token can be as useful to a thief as the app itself.
- **App-level access** is usually broader than access on behalf of one user, and deserves extra scrutiny.

CHAPTER 3

# What Are You Actually Allowing?



An approval screen usually shows a short list of lines written by the app's developer or the platform. This chapter helps you translate those lines into business terms.

A caution first. **What an app can do depends on the provider, the specific permission scope, how the app is designed and how your account is configured.** The examples below describe common kinds of capability. They are not a catalogue of any one product, and the wording on your screen will differ.

## What permissions can let an app do

| Area | Examples of what a granted permission may allow |
|---|---|
| **Email and messages** | Read message content and attachments; search the mailbox; draft; send messages that appear to come from you; move or delete messages |
| **Calendar** | See your free/busy times only, or see full event details and attendee names; create, change or cancel events |
| **Cloud files** | View a chosen file or folder, or everything you can reach; upload; edit; share outside the organisation; delete |
| **CRM records** | Read contact and deal data; create or update records; export lists; delete |
| **Contacts** | Read names, emails and phone numbers of everyone in your address book |
| **Workflows** | Trigger automated actions, such as sending a message, creating an invoice or posting to a channel |
| **Organisation-wide data** | Where an administrator has approved it, reach data belonging to many users, subject to the permission granted |

Two points deserve emphasis.

**It is often "you plus the app".** In delegated access, the app can generally reach what *you* can reach. [7] If you are an owner or administrator with access to everything, an app you authorise inherits a very wide view. A junior employee's authorisation will typically reach less. The same app carries different risk depending on who clicks.

**Sending is its own category.** Permission to *send* as you means an app, or anyone controlling it, can write to your customers, suppliers or bank in your name.

## Five levels of access

A useful way to read any permission is to place it on a ladder from least to most powerful.




The access ladder. Each rung up adds power, and each deserves a sharper question.

- **Read-only (limited):** the app can look but not change. Example: see which dates you are free.
- **Read-only (broad):** the app can read a lot, such as your whole mailbox. Reading is not harmless if the content is confidential or personal.
- **Read and write:** the app can create or change things. Example: add calendar events, or edit documents.
- **Send, share or delete:** the app can act outwardly (send as you, share files with outsiders) or destructively (permanently remove items).

- **Administrative or organisation-wide:** the app can manage users, settings or other people's data. This rung needs a named owner and a strong reason.

Platforms commonly flag some scopes as "sensitive" or "restricted". Google, for instance, requires production apps using certain sensitive or restricted scopes to go through a verification step. [6] That is a useful checkpoint, but **a verified app is not a guaranteed safe app**, and nothing in verification replaces your own judgement about whether you need the access.

## The permission comparison table

Use this table as a reading aid. It is a general guide, not a statement about any particular product.

| Capability | Business benefit | Possible risk | Review questions |
|---|---|---|---|
| **Read email** | Summaries, search, filing | Exposes confidential and personal content, including attachments | Does it need all mail, or just one label or folder? Who can see the output? |
| **Send email** | Automatic replies, follow-ups | Messages sent in your name; impersonation if misused | Is sending essential? Could a sender-only or draft-only option do? |
| **Delete email or files** | Tidy-up, clearing space | Loss of records; evidence destroyed | Why does it ever need to delete? Is there a backup? |
| **Calendar (free/busy)** | Easy booking | Minimal; reveals when you are away | Is free/busy enough, or does it ask for event details? |
| **Calendar (full details)** | Meeting prep, notes | Attendee names, client meetings and locations | Is there a reason to see event titles and guests? |
| **View cloud files** | Search, attach, report | Whole-drive exposure if scope is "all files" | Can access be limited to one folder? |
| **Edit or share cloud files** | Collaboration, publishing | Data leaks via external sharing links; accidental overwrites | Can sharing be restricted to named people? |
| **Read CRM data** | Reporting, enrichment | Customer lists and notes exposed | Which fields and records? Is personal data included? |
| **Write or export CRM data** | Sync, automation | Bulk change or export of the customer base | Does it need export? Who is notified? |
| **Read contacts** | Auto-complete, invitations | Everyone you know, including customers | Is the whole address book necessary? |

| Capability | Business benefit | Possible risk | Review questions |
|---|---|---|---|
| **Trigger workflows** | Saves manual steps | Chains actions across systems | What can the workflow reach if misused? |
| **Admin / organisation-wide** | Central management | One compromise reaches every user's data | Who approved it? Is it reviewed every quarter? |

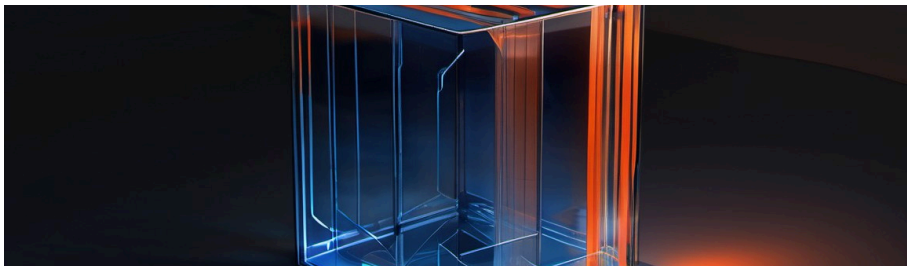
**The rule.** Read the verb, then the noun. *Read*, *edit*, *send*, *share*, *delete*, *manage*. Then *one folder*, *one mailbox*, *or everything*. The riskiest words are at the end of both lists.

## Takeaways

- **Read what the permission lets the app do**, not just the app's name.
- **Sending, sharing, deleting and admin rights** are the rungs to question hardest.
- **Who clicks matters.** An owner's authorisation can reach more than a junior's.
- **Verification by a platform is a checkpoint, not a guarantee.**

CHAPTER 4

# Five Connected-App Risks Small Businesses Overlook



This chapter covers five places where connected apps tend to cluster. For each, a fictional example, what could be exposed, how the risk arises, warning signs and preventive steps follow. **None of the products named is real, and nothing here suggests that any real product is unsafe.** The point is to teach patterns.

## 1. Email and calendar integrations

> **Fictional example.** *A four-person consultancy connects "InboxPilot", an inbox assistant, to the director's mailbox so it can draft replies. The consent screen asks for full read, send and delete access. Months later the director's mailbox contains contracts, a client's tax correspondence and password-reset emails for several services.*

**What could be exposed or changed.** Message content and attachments; the history of conversations with clients; password-reset links delivered by email; the ability to send as the director; and the calendar showing who is meeting whom.

**How the risk could arise.** The app, or the company behind it, is compromised or sold. An employee leaves but the app stays connected. The assistant's data-handling terms allow broader use of content than the director realised. A mailbox is also a key to other accounts, because many services send reset links by email.

**Warning signs.** Sent messages you do not recognise; rules or forwards you did not create; an unfamiliar app in your account's connected-apps list; consent prompts that suddenly appear again.

**Practical measures.**

- Prefer the narrowest option available: a single label, or "compose drafts" instead of "send".
- Do not connect email to tools whose purpose you cannot explain in one sentence.
- Record the connection in your inventory (Appendix B) with a named owner.
- Check what the vendor says it does with email content, and whether a data-processing agreement is available (Chapter 9).

## 2. Cloud storage and document-sharing apps

> **Fictional example.** *A small architecture practice lets a "DocuStamp" add-on stamp PDFs. The authorisation screen requests access to "see, edit, create and delete all of your files". The practice's drive holds client drawings, staff contracts and scanned passports.*

**What could be exposed or changed.** Everything the authorising user can reach: client files, HR records, financial documents, backups kept in the same drive. Files can be changed, deleted, or shared through links to people outside the business.

**How the risk could arise.** "All files" scopes are easy for developers to request and easy for users to accept. If the app is breached, or its token is misused, the reach is the whole drive. External sharing links created by an app may stay valid long after the project ends.

**Warning signs.** Files appearing in unfamiliar folders; unexpected "shared with" entries; storage activity at odd hours; add-ons nobody remembers installing.

**Practical measures.**

- Choose per-file or per-folder access where it exists; reject "all files" for a narrow task.
- Keep sensitive folders (HR, finance, client IDs) in locations that connected apps are not permitted to reach, where your platform supports it.
- Check sharing settings regularly: who has link access, and to what.

- Keep an independent backup, so that a mistaken or malicious deletion by an app is recoverable. The NCSC's small-organisation guidance lists backups among its core topics. [11]

## 3. CRM and customer-management integrations

> **Fictional example.** *A garden-design company connects "ReviewRocket" to its CRM so that it can send satisfaction surveys. The integration is granted rights to read and export all contacts, notes and deal values. Two years later, the supplier stops trading, and nobody confirms what happened to its copy of the data.*

**What could be exposed or changed.** Names, addresses, phone numbers, emails, purchase history, notes (which often hold informal personal details) and deal values. Bulk export is the main concern: a single request can copy a customer base.

**How the risk could arise.** Integrations frequently ask for full CRM access because it is simpler for the developer. Data copied into the vendor's system persists beyond the connection. Vendors can change ownership. Under data-protection law, the personal data in your CRM remains your responsibility even when a supplier holds a copy (Chapter 9).

**Warning signs.** Large exports in the activity log; marketing messages to customers you did not authorise; bounced emails from your own system; duplicate or altered records.

**Practical measures.**

- Ask what fields the integration really needs; request minimal access.
- Where possible, give integrations their **own dedicated user** with restricted rights, not an administrator's identity, so activity is traceable and access is limited.
- Check the supplier's data-retention and deletion process before you connect, and again before you disconnect.
- Review exports and API activity logs if your CRM offers them.

## 4. AI assistants, browser extensions and productivity tools

> **Fictional example.** *A sales team adopts "NoteNest", an AI meeting recorder, and a browser extension called "QuickReply". The recorder joins every calendar event and stores transcripts. The extension asks to "read and change all your data on the websites you visit".*

**What could be exposed or changed.** Meeting content and transcripts, including client discussions; calendar details; whatever appears in web pages such as webmail, the CRM and the banking portal, if an extension can read them; documents pasted into an assistant.

**How the risk could arise.** AI tools are attractive because they ask to read a lot in order to be helpful, and they are adopted quickly, often by individuals. What happens to content afterwards is set by each provider's terms, such as retention, human review or use for improving the service, and those terms differ. Browser extensions can request very broad rights, and extensions can change hands after you install them.

**Warning signs.** Tools that appear in meetings without being invited; extensions you cannot place; staff pasting client material into tools nobody has assessed; vague answers to "where does the data go?".

**Practical measures.**

- Create a short list of **approved AI tools** and say what may not be shared with them.
- Read the data-use, retention and training terms. If you cannot find them, treat that as an answer.
- Limit browser extensions to those that the business needs, and review them in the same quarterly audit.
- Prefer business accounts with administrator controls over personal sign-ups.

## 5. Automation platforms that connect multiple services

> **Fictional example.** *A marketing agency uses "FlowLink" to link its mailbox, CRM, accounting package and shared drive. Workflows (each platform has its own word for them) were built over two years by four different people, three of whom have left. One flow still sends invoices.*

**What could be exposed or changed.** Potentially everything the connected accounts allow, in one place: email, customer records, financial documents and files. Automation tools also **act**: they send, create, update and delete without a person watching.

**How the risk could arise.** An automation platform holds tokens or keys for many systems at once, so one account compromise (a reused password, say) can reach all of them. Flows built by departed colleagues persist and may run with their credentials. Small changes to one flow can have effects in another system.

**Warning signs.** Flows nobody can explain; connections made with a former employee's login; runs that fail silently; an unexplained spike in activity.

**Practical measures.**

- Protect the automation account itself with the strongest sign-in available, and keep a **named owner** for the account.
- Use **dedicated service accounts**, not individuals' accounts, for connections, so a departure does not break or orphan them.
- List every flow and the systems it touches (a flow list is part of your inventory).
- Delete flows that are no longer used, rather than pausing them.

## A common pattern

Across all five areas, the pattern is the same: **broad permission, no owner, no end date.** The preventive measures are also the same: narrow the scope, name an owner, record the purpose, review on a schedule.

## Takeaways

- Look for connected apps in **five places**: email and calendar, cloud storage, CRM, AI and extensions, and automation platforms.
- The **same three failings** recur: broad access, no owner and no review.
- **Prevention is mostly administrative**: narrow the permission, name an owner, record the purpose and set a review date.

CHAPTER 5

# The Difference Between Useful Access and Excessive Access



You cannot review a connection without a yardstick. This chapter gives you one, built on a principle security professionals have used for decades.

## Least privilege

**Least privilege** means giving a person, system or application only the minimum access needed to do its assigned job, and no more. [21] The same idea appears in security standards bodies, in the OAuth security guidance, which recommends restricting access tokens to the minimum needed, [2] [3] and in Google's developer policy, which tells app makers to request the smallest set of scopes that delivers the feature a user has chosen. [6]

It is not about distrust. It is about **limiting the damage if something goes wrong**: if an app that can only read one calendar is compromised, the worst case is small. If the app can delete every file, the worst case is large.

## Seven questions to ask about any connection

1. **Does the app need access to this data at all?** If the feature works without it, the permission is not needed.
2. **Does it need to modify or delete?** Many tools only need to look. A "read" permission is usually less risky than "read and write".
3. **Does it need the whole account, or only selected resources?** One folder, one calendar or one label is better than everything.
4. **Is the permission needed for the feature you actually use?** Apps sometimes request rights for features you never switch on.
5. **Could a less powerful integration do the job?** Another tool, a built-in feature or a manual step might do it.

6. **Who approved the connection?** An approval with no name attached is a warning sign.
7. **What happens when the employee leaves or the project ends?** If the answer is "it carries on", that is a risk.

## A simple risk rating

Use four ratings: **Low, Medium, High and Critical**. Appendix C gives a scoring method. The scheme is a **practical screening tool for small businesses, not a formal security certification, audit or standard**. Its job is to help you decide what to look at first.




Four ratings, and what each normally calls for.

Each connection is scored from 1 (lower concern) to 3 (higher concern) on five factors, and the five scores are added.

| Factor | 1 | 2 | 3 |
|---|---|---|---|
| **Data sensitivity** | Little or none | Internal business information | Personal, financial, confidential data or credentials |
| **Breadth of access** | One folder, calendar or record type | A whole mailbox, drive or system | Many users or the entire organisation |
| **Power** | Read-only | Create, edit or send | Delete, share externally, manage permissions or administer |
| **Necessity** | Essential and regularly used | Useful but replaceable | Rarely used, or nobody can say why |
| **Assurance gaps** | Known supplier, named owner, terms reviewed | Some gaps (no recent review, unclear data terms) | Unknown supplier, no owner or never reviewed |

| Total | Rating | Normal response |
|---|---|---|
| 5 to 7 | **Low** | Retain; check at the next quarterly review |
| 8 to 10 | **Medium** | Retain or restrict; confirm owner and purpose |
| 11 to 13 | **High** | Restrict, investigate or revoke; act this month |
| 14 to 15 | **Critical** | Investigate and likely revoke now |

**Override.** If both *Breadth* and *Power* score 3, treat the connection as at least High, whatever the total.

## Worked examples

> **Fictional example.** *Northgate Print & Design is a nine-person studio. Its three connections below are invented for teaching. None of the products exists.*

**Connection A: MeetSlot, a booking page.** Staff authorised it to read and create events on their own calendars. The business owner approved it and uses it weekly.

| Factor | Score | Why |
|---|---|---|
| Data sensitivity | 2 | Calendars show client names and times |
| Breadth | 1 | Calendar only |
| Power | 2 | Creates events |
| Necessity | 1 | Used weekly |
| Assurance gaps | 1 | Named owner; terms read last year |
| **Total** | **7** | **Low** |

*Decision: retain. Confirm at the next review that nothing has changed.*

**Connection B: InboxBuddy, an AI email helper.** A freelancer connected it to the studio's shared mailbox "to try it". It can read, send and permanently delete mail. Nobody is sure who pays for it, and no one has read its terms.

| Factor | Score | Why |
|---|---|---|
| Data sensitivity | 3 | Client contracts and personal details |
| Breadth | 2 | One whole mailbox |
| Power | 3 | Can delete and send |
| Necessity | 2 | Useful but replaceable |

| Factor | Score | Why |
|---|---|---|
| Assurance gaps | 3 | No owner, no terms reviewed |
| **Total** | **13** | **High** |

*Decision: restrict or revoke. Ask the freelancer why it was connected, check whether the team relies on it, and review the vendor's data terms before any reconnection with narrower access.*

**Connection C: SyncStack, an automation platform.** A former contractor set it up with administrator approval to reach every file in the shared drive. It last ran eight months ago, and the contractor left in the summer.

| Factor | Score | Why |
|---|---|---|
| Data sensitivity | 3 | Whole drive including HR and finance |
| Breadth | 3 | Organisation-wide |
| Power | 3 | Can edit, share and delete |
| Necessity | 3 | Unused and unexplained |
| Assurance gaps | 3 | Owner gone; no review |
| **Total** | **15** | **Critical** |

*Decision: investigate and revoke. Check the activity log first, so you know whether it has done anything since it stopped running. Then remove access and test.*

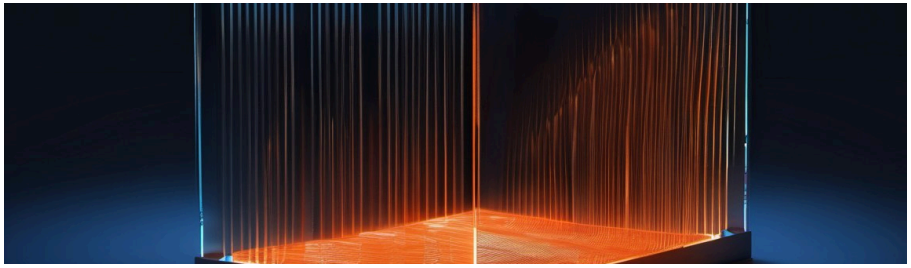
> **The rule.** An app does not earn broad access by being convenient. It earns broad access by being necessary, owned and reviewed.

## Takeaways

- **Least privilege** means the minimum access needed, reducing the damage if something goes wrong.
- Ask the **seven questions** of every connection, new or old.
- Use the **Low / Medium / High / Critical** screen to decide what to look at first. It is a triage tool, not a certification.

CHAPTER 6

# How Connected Apps Become a Security Problem



Connected apps usually work as intended. When they do not, the trouble tends to follow a handful of routes. Knowing the routes helps you spot weak points before anything happens.

## Eight routes

1. **A compromised third-party application.** An attacker gets into the app provider's systems and finds tokens or data stored there. Every customer connected to the app is potentially affected.
2. **A legitimate app that becomes compromised.** An app that was trusted for years suffers a breach, changes hands or is taken over. The permission you granted earlier still applies.
3. **A malicious or deceptive application.** An app built to look helpful, or to resemble a known one, asks for access and misuses it. Microsoft describes "illicit consent grant" attacks, in which an attacker registers an app, then tricks a user into consenting, giving the app account-level access to data without needing an account in the organisation. [9]
4. **Excessive permissions.** The app is honest and secure, but can reach far more than it needs, so any mistake or breach affects more.
5. **Stolen or misused tokens.** Because a token stands in for a sign-in, a stolen one may be used without a password. Guidance exists for developers on protecting tokens, but you cannot assume every app follows it. [2][3]
6. **Poorly managed integrations.** Connections built quickly, tied to individual accounts, with no record of why they exist.
7. **Unnecessary access left active.** The project ended, the trial lapsed, the employee left, and the permission stayed.

8. **Human error and weak approval.** In many organisations, anyone can click **Allow**. If no one is expected to check, or no one knows whom to ask, risky approvals become normal.

A point worth stating plainly: Microsoft notes that normal remediation steps such as resetting passwords or requiring multi-factor authentication aren't effective against an illicit consent grant, because the app is external to the organisation and holds its own authorisation. [9] **The authorisation itself must be found and removed.** That is why a connected-app review is a separate job from general account security.

## Possible risk is not evidence of an incident

The difference matters for how you react and, in some cases, for your legal duties.

| | Possible risk | Evidence of an incident |
|---|---|---|
| What it looks like | An app has more access than it needs; nobody owns it | Unexplained mail sent, files moved, large exports, access from unfamiliar sources |
| What you know | A route exists | Something may actually have happened |
| Normal response | Fix it in the ordinary review cycle | Preserve logs, involve your IT or security provider, follow your incident process |
| Data-protection angle | Reduce risk; document the decision | Assess whether a personal data breach has occurred (Chapter 9) |

Finding an over-permissioned app does not mean you have been breached. It means you have found a risk to reduce. Equally, do not wait for a certainty before you ask for help when you see real signs of misuse.

## A real, verified example: tokens at a third-party app

You do not have to rely on made-up stories to see route 2 in action. In August 2025, the Google Threat Intelligence Group (GTIG) published an analysis of a data-theft campaign involving Salesloft Drift, a chat and sales-engagement application. [10]

What GTIG reported, in summary:

- A threat actor, from as early as 8 August through at least 18 August 2025, used **compromised OAuth tokens associated with the Drift third-party app** to access a number of corporate Salesforce instances. GTIG stated that this was **not a vulnerability in the core Salesforce platform**.

- The actor exported large volumes of records, including Account, Case, User and Opportunity data, and then searched them for secrets such as cloud access keys and passwords. GTIG assessed that the main aim was harvesting credentials.
- On 20 August 2025, Salesloft and Salesforce revoked all active Drift access and refresh tokens.
- In an update of 28 August, GTIG said the scope was broader than the Salesforce integration: tokens for a Drift email integration had also been used on 9 August to read email from a very small number of Google Workspace accounts that were configured to integrate with Drift. Google revoked those tokens and disabled that integration.
- Among its recommendations, GTIG advised organisations to review all third-party integrations, revoke and rotate affected credentials, and **limit connected-app scopes to the minimum needed**.

Three lessons for a small business, offered as the author's reading rather than GTIG's: the weak point was a trusted outside app, not the platform itself; the access worked without a user signing in; and the best protection available to customers was knowing which integrations they had and being able to remove them quickly. That is exactly what the review in this book trains you to do.

## Case study: how a harmless-looking integration could expose customer data

**Fictional example.** *Ashby Vale Physiotherapy is a six-clinic practice. Every name, product and event in this case is invented.*

**Month 0.** The practice manager connects "RecallRight", a reminder tool, to the booking system. The consent screen asks to *read and export all patient contact records*, because that is simpler for the developer than requesting only appointment times. Nobody is concerned; the vendor looks professional.

**Month 3.** The trial becomes a paid plan on a staff member's personal card. The account is registered with her personal email address.

**Month 10.** She leaves. The tool keeps running. Nobody has her login. Nobody else knows the tool exists.

**Month 14.** RecallRight's developer suffers a breach of its own systems. Stored authorisation tokens for many customers, including the practice, are copied.

**Month 14, one week later.** An unfamiliar party uses the practice's token to request an export of patient contact records. The booking system's activity log records an unusually large export from the RecallRight connection at an hour when the clinics are closed.

**Month 16.** A patient receives a convincing text message, naming her practice and her last appointment, asking her to pay a "cancellation fee". She reports it.

**What went wrong, step by step:**

| Step | Failure | Which control would have helped |
|---|---|---|
| Permission requested | Export of all patient records, when appointment times would do | Least-privilege review at approval |
| Billing on a personal card | Purchase invisible to the business | Approval form; finance check |
| Employee left | Owner departed, nobody took over | Departure checklist for connected apps |
| Token stolen at the vendor | Not within the practice's control | Short review cycle; ability to revoke quickly |
| Export went unnoticed | Nobody reviewed activity | Quarterly audit; log check |

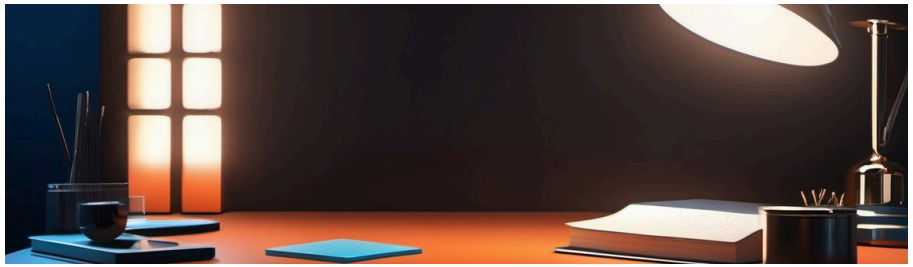
**What it would not prove.** The text message does not by itself show that RecallRight was the source. Patients may receive such messages for many reasons. The practice would need to investigate, with its IT provider, before drawing conclusions, and would have to consider its data-protection duties (Chapter 9).

## Takeaways

- Trouble tends to come by **eight routes**, most of them unglamorous: broad permissions, forgotten access, no owner.
- **Password resets do not remove an app's authorisation.** Find and revoke it.
- Separate **a possible risk** from **evidence of an incident**, and respond accordingly.
- The real Drift campaign shows why you must **know your integrations and be able to remove them quickly**.

CHAPTER 7

# How to Review Connected Apps



This chapter is a procedure you can follow without being a cybersecurity specialist. It works with a pen and paper, a spreadsheet or the worksheets in the appendices.

**Menu names and available controls vary between providers and change without notice.** Treat the platform-specific steps below as signposts that were checked against official documentation on the dates given, and be ready to adapt if your screen differs.

## The ten steps




The ten-step review. Steps 1 to 4 find the connection; 5 to 8 judge it; 9 and 10 decide and record.

**Step 1. Identify your business accounts and platforms.** List where business data lives: email, calendar, cloud storage, CRM, accounting, helpdesk, project management, chat, marketing, automation and AI tools. Include

accounts held by individuals, such as a freelancer's own storage that holds your files.

**Step 2. Locate the connected-app or third-party access settings.** Each platform has a place that lists apps with access. Look under headings like *Security*, *Apps*, *Integrations*, *Connected apps*, *Marketplace*, API or *Authorised apps*. If you cannot find it, search the provider's help for "third-party access" or "connected apps".

**Step 3. Record the application name and business purpose.** Write down the name exactly as shown, and what it is for in one sentence. If nobody can say, note it. That is already a finding.

**Step 4. Identify the account or data involved.** Which mailbox, drive, CRM or calendar is connected, and whose?

**Step 5. Review the requested or granted permissions.** Copy the permission wording as shown. Place each on the ladder in Chapter 3.

**Step 6. Identify the application owner and the approving employee.** The *owner* is the person in your business who is responsible for the connection. The *approver* is the one who clicked or authorised it. They may differ, and either may have left.

**Step 7. Check whether the integration is still required.** Look at last-used dates if shown, and ask the owner.

**Step 8. Assess its permissions and business impact.** Apply the seven questions and the score from Chapter 5. Also ask what would stop working if you removed it.

**Step 9. Decide: retain, restrict, investigate or revoke.**

| Decision | Meaning | Typical case |
|---|---|---|
| **Retain** | Keep as is | Needed, narrow, owned |
| **Restrict** | Keep, but reduce scope, move to a service account or add conditions | Needed, but access broader than required |
| **Investigate** | Pause on a decision until you know more | Unknown purpose, odd activity, or a large export in the log |
| **Revoke** | Remove access | Unused, unowned, excessive or suspect |

**Step 10. Record the decision and the next review date.** An unrecorded review will have to be repeated from scratch next time.

## A provider-neutral checklist

Use this for any platform.

- ☐ I have found the list of connected or authorised apps for this account.
- ☐ Every app on the list has a name, a purpose and a business owner written down.
- ☐ I know which account or data each app can reach.
- ☐ I have read the permissions for each app, not only its name.
- ☐ I have flagged apps with send, share, delete or administrator rights.
- ☐ I have checked whether each app is still used.
- ☐ I have checked who approved each one, and that this person is still here.
- ☐ I have scored each app and decided retain, restrict, investigate or revoke.
- ☐ I have recorded my decisions and set the next review date.

## Platform-specific pointers (verified against official documentation)

*These pointers were checked against the provider pages in the source list in late October 2026. They describe what the documentation said then.*

**Google Account (personal or individual).** Google's help page for sharing account data with other developers' apps links to a "linked apps" page (myaccount.google.com/linkedapps), where you can see apps with access to your account and remove access at any time. [4] It does not give click-by-click steps, so follow the on-screen options you see.

**Google Workspace (administrators).** Google's documentation states that administrators with the Service Settings privilege can go to *Menu* > *Security* > *Access and data control* > *API controls*. [5] There, **Manage App Access** lists configured apps, and **Accessed apps** (View list) shows apps that have accessed Google data, with user counts and requested services. **Apps pending review** lists user requests. The list can be downloaded as a CSV file. Details typically appear 24 to 48 hours after authorisation. Administrators can set an app as **Trusted**, **Limited**, **Specific Google data** or **Blocked**, and can choose what happens with **unconfigured** apps: allow any, allow only basic sign-in, or allow none. [5]

**Microsoft Entra ID (Microsoft 365 business tenants).** Microsoft's documentation says that, signed in as at least a Cloud Application Administrator, you go to *Entra ID* > *Enterprise apps* > *All applications*, select

the app and choose **Permissions**. The **Admin consent** tab shows what applies to the whole organisation; the **User consent** tab shows what individuals have granted. [8] To see the apps a particular person has authorised, Microsoft's illicit-consent guidance points to *Identity* > *Users* > *All users*, then the user's **Applications** page, and says users can also review their own access at myapps.microsoft.com. [9] Microsoft also describes searching the audit log for "Consent to application" events and checking whether admin consent was used. [9]

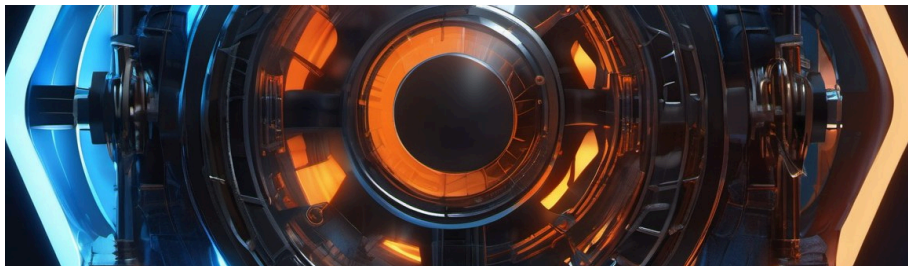
**Other platforms** (CRM, accounting, chat, marketing and project-management tools). Their steps are not covered here because they were not verified for this edition. Use the provider's official help pages, and search for words like "authorised apps", "connected apps" or "API access".

## Takeaways

- Follow the **same ten steps** on every platform, even when the menus differ.
- **Write down** the purpose, owner and permissions for every app. Gaps are findings.
- Decide **retain, restrict, investigate or revoke**, and record the date of the next review.

CHAPTER 8

# Revoking Access Without Breaking Your Business



Once you know what you have, you will find some connections to remove. Removing access is easy. Removing it **without a surprise** takes a little care.

## A safe order of work

1. **Confirm the app's business purpose.** Ask the apparent owner. If nobody claims it, that is a reason to revoke, but still to look at its recent activity first.
2. **Check whether important workflows depend on it.** Look for invoices, reminders, reports, onboarding or website forms that might break. Ask the department that would feel it first.
3. **Identify the business owner before removal,** and tell them.
4. **Record the current configuration.** Take a screenshot or note the app name, account, permissions, connection date and any linked automations. If you need to reconnect, you will want to know how it was set up, and ideally reconnect more narrowly.
5. **Revoke through the provider's controls.** Use the platform's own place for removing access, not just deleting an icon or uninstalling software (Chapter 1).
6. **Check that access has actually been withdrawn.** Refresh the list and confirm the app is gone, or its access shows as removed. For administrator-level controls, check that the setting applies to the right organisational unit or user.
7. **Review related tokens, permissions and integrations where supported.** Some providers hold separate items: user-level and organisation-level grants, API keys, linked service accounts. Microsoft's guidance, for

instance, distinguishes admin-consented permissions from user-consented ones, and says that permissions on the user-consent side cannot be revoked in the portal and need other tools. [8]

8. **Test critical workflows afterwards.** Send a test invoice, submit a test form, check that a calendar still books.
9. **Document the action.** Record what was removed, by whom, when, and why (Appendix A's decision log).

## What revoking does and does not do

> **The rule.** Revoking an authorisation stops the app reaching your data from that moment. It does not take back what the app has already copied.

Google's help page says exactly this: if you revoke a linked app's access, it can no longer access your data, but you may need to contact the developer to ask them to delete data they already hold. [4] The same logic applies on any platform.

So after revoking, where personal or confidential data was involved:

- Find the vendor's **data-retention and deletion process**, normally in its privacy policy, terms or support pages.
- Ask for **deletion** of data you no longer want them to hold, and keep the reply.
- If a contract or a data-processing agreement exists, check what it says about deletion at the end of the relationship (Chapter 9).

Also bear in mind that **revoking does not always prevent re-authorisation**. Microsoft notes that revoking a granted permission does not stop users from consenting again to the application's requested permissions; to prevent that you must change how consent is configured. [8]

## When the situation looks serious

If you have *evidence* rather than just risk, such as unexplained messages sent from an account, large unexpected exports, or an unknown app with broad access on a senior person's account, the calm review process is not enough on its own.

- **Escalate** to your IT support or security provider at once, if you have one.

- **Preserve evidence**: do not delete logs, messages or the app entry until someone has recorded them.
- Consider **revoking quickly** to stop further access, but note the details first. Microsoft's guidance also lists short-term measures, such as disabling sign-in for an affected account. [9]
- **Rotate secrets** that the app or its data may have exposed, such as API keys and passwords stored in documents. GTIG's advice on the Drift incident included revoking and rotating credentials for affected integrations. [10]
- **Follow your incident-response process,** and assess whether personal data has been involved (Chapter 9).
- In the UK, the NCSC has advice for small organisations on responding to attacks, including hacked accounts, and points to a government service at gov.uk/report-cyber for finding out where to report. [12][20]

Appendix E is a checklist for exactly these moments.

## Takeaways

- **Check, record, revoke, verify, test, document**: in that order.
- **Revoking is not deleting.** Follow up with the vendor about data it holds.
- **Evidence of misuse changes the process:** escalate and preserve evidence before tidying up.

CHAPTER 9

# Connected Apps and GDPR



**This chapter is general information, not legal advice.** The GDPR applies to personal data, and what it requires depends on your circumstances. Connecting an app does not automatically breach the GDPR. Whether you comply depends on your purposes, your lawful basis, your contracts, your security measures and other facts that this book cannot know. For complex or high-risk situations, take qualified advice.

**Which law?** The EU GDPR applies in EU member states. The UK has its own version, the UK GDPR, supplemented by the Data Protection Act 2018, and the ICO is the regulator. UK data-protection law has been amended in recent years, so check the ICO's current guidance. Article numbers below are shared by both versions unless noted, but wording and details can differ.

## Why access is a data-protection matter

If your email, drive or CRM contains information about identifiable people, such as customers, staff, suppliers' contacts or website visitors, it is **personal data**. A connected app that can read or copy it is, in effect, another route by which personal data is handled. Examples in typical connected systems:

- customer names, addresses, emails and phone numbers in a CRM;
- staff contracts, ID scans and bank details in cloud storage;
- the content of emails and meeting recordings;
- calendar entries that reveal appointments with named people.

## Controllers and processors

A **controller** decides why and how personal data is processed. A **processor** processes personal data on the controller's behalf. A small business is usually the controller of its customer and staff data, and an app vendor that handles that data for you is commonly acting as a processor. But the roles depend on the facts, and a vendor may be a controller for some of its own purposes, such as account administration. The European Data Protection Board's guidelines on the concepts of controller and processor explain how to tell them apart, [18] and the ICO has guidance for UK organisations. [16]

## Choosing and overseeing a vendor

Under Article 28, a controller may only use a processor offering *sufficient guarantees* of appropriate technical and organisational measures, and the processing must be governed by a binding contract or other legal instrument that sets out subject matter, duration, nature and purpose of processing, the types of personal data and categories of people, and the controller's obligations and rights. [19] In practice, that is the **data processing agreement (DPA)**. Many vendors publish a standard one. The question for you is simply: *when an app processes personal data for us, do we have one, and have we read it?*

The ICO's data-security guidance similarly says to choose processors with adequate security and to be able to verify it. [15]

## The principles that matter most for connected apps

- **Purpose limitation** (Article 5(1)(b)). Use personal data for specified purposes. Connect an app for the purpose you actually have.
- **Data minimisation** (Article 5(1)(c)). Process only what is adequate, relevant and necessary. This is the data-protection twin of least privilege: an app that takes the whole CRM when it needs appointment times is hard to reconcile with it.
- **Security** (Article 5(1)(f) and Article 32). Take appropriate technical and organisational measures for the risk. The ICO says access to personal data should be limited to authorised people and only to the extent their role requires. [15] Reviewing which apps have access is one reasonable measure.
- **Accountability** (Article 5(2)). Be able to show what you decided and why. An audit worksheet and a decision log are good evidence.

- **Data protection by design and default** (Article 25). Prefer the privacy-friendly setting when choosing tools.

## Records of processing

Article 30 requires certain organisations to keep records of processing activities. There are exemptions for small organisations, but they do not apply in every case, for example where processing is not occasional or involves certain data. Check the ICO's guidance on whether you need one. If you keep records, your connected-app inventory is a natural source for the "who receives the data" part.

## Incidents and breach response

A personal data breach is a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data. The ICO states that if a breach is likely to create a risk to people, you must notify the ICO as soon as possible and, where feasible, within 72 hours; if the risk is high, you must also tell the affected people without undue delay. [17] The key step for connected apps is the one in Chapter 6: **work out whether you have only a risk, or evidence that data was actually accessed.** If a vendor tells you it has had a breach, note the date, because your own clock may start when you become aware of an incident affecting your data. Record your assessment even when you decide not to report.

## International transfers

Many vendors store data outside the UK or EEA. Rules on transferring personal data to other countries apply where relevant (Chapter V of the GDPR). Which mechanism applies depends on the destination, the vendor and the data. Ask the vendor where data is stored and processed, and what transfer mechanism it relies on, and take advice if the answer is unclear.

## A practical checklist, not a verdict

- ☐ Does the app handle personal data from this system?
- ☐ Do we know the vendor's role, and is there a DPA where one is needed?
- ☐ Does the app need all the data it can reach?
- ☐ Do we know where the vendor stores and processes the data?
- ☐ Can we remove access and request deletion if we stop using it?

☐ Have we recorded the decision?

Answering "no" to any of these is not proof of a breach. It is a prompt to find out.

> **The rule.** Compliance is not a property of the app. It is a property of how *you* chose, configured, contracted for and supervised it.

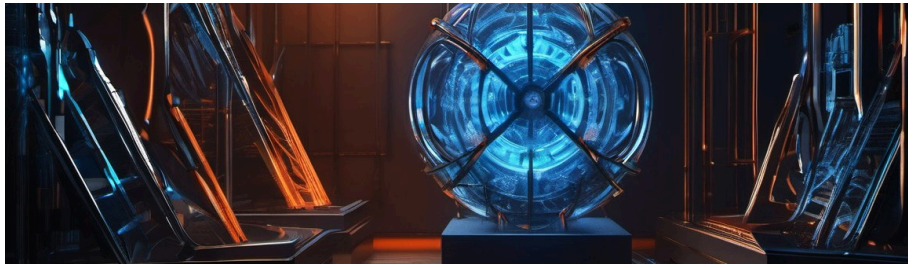
**Further reading on suppliers.** The NCSC's supply chain security guidance is aimed at organisations that rely on suppliers, [13] and its cloud security guidance has a section on choosing a cloud provider. [14] Both are written with larger organisations in mind, but the questions carry over.

## Takeaways

- **Personal data in connected systems is your responsibility** even if a vendor holds a copy.
- **Minimisation and security** are the two principles most affected by app permissions.
- **Keep a DPA** where an app processes personal data for you.
- **Qualified advice** is for complex or high-risk cases. This chapter is not a legal verdict.

CHAPTER 10

# Build a Simple Connected-App Policy



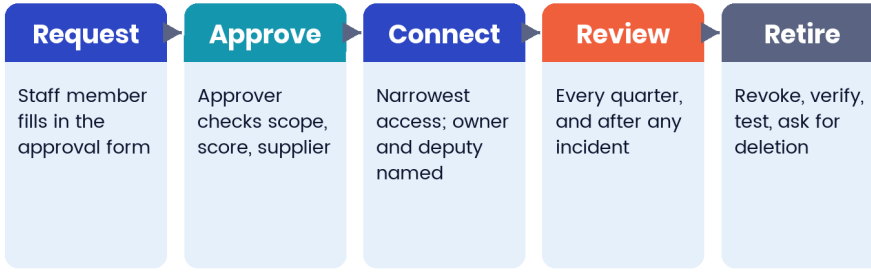
A policy is how a one-off clean-up becomes a habit. The goal is not to write something that sounds official. It is to give staff clear answers to three questions: *Can I connect this? Who do I ask? What happens when I leave?*

A copy-ready policy is in **Appendix F**. This chapter explains the choices inside it so that you can adapt it with confidence.

## The ten decisions

| Policy element | The decision you are making | A sensible small-business default |
|---|---|---|
| **Who may authorise** | Who can say yes to a new integration | The named approver, plus the system owner for high-risk requests |
| **Which systems need approval** | Where connections are covered | Email, calendar, cloud storage, CRM, accounting, HR and any system with customer or staff data |
| **How scopes are reviewed** | What the approver checks | The seven questions from Chapter 5, plus a risk score |
| **Customer and employee data** | Extra rules for personal data | Data-protection check; DPA where needed; storage location asked |
| **Business purpose** | What must be written down | One sentence, plus the data involved |
| **Ownership** | Who is accountable | Every connection has one named owner and a deputy |
| **Employee departures** | What happens to a leaver's connections | Connections reassigned or revoked on the last day |
| **Emergency revocation** | Who can remove access fast | Named people may revoke first and explain after |
| **Review frequency** | How often to re-check | Quarterly, with an immediate review after any incident |

| Policy element | The decision you are making | A sensible small-business default |
|---|---|---|
| **Exceptions and escalation** | How to handle awkward cases | A written, time-limited exception, approved by the owner/director |




The life of a connection, from request to retirement. Every stage has a named person.

## Principles worth keeping

**Keep it short.** A two-page policy that people read beats a ten-page one they do not.

**Name roles and people.** "IT" is not an owner. If your business has no IT department, say which person does the job.

**Make the safe route easy.** If getting approval takes a week, people will connect things anyway. Offer a quick form (Appendix D) and a response time you can meet.

**Cover personal accounts.** State that business data should not be connected to apps through personal accounts, and that staff must not connect business accounts to apps without approval.

**Plan for departures.** Add connected apps to your leaver checklist. This is one of the commonest ways access outlives its purpose (Chapter 4).

**Do not overpromise.** A policy lowers risk. It does not remove it, and it does not guarantee compliance.

## Takeaways

- A policy answers: **who approves, what is checked, who owns, what happens on departure, how often we review.**
- Adapt **Appendix F** to your business and put real names in the placeholders.
- A **short, usable** policy is more effective than a thorough, ignored one.

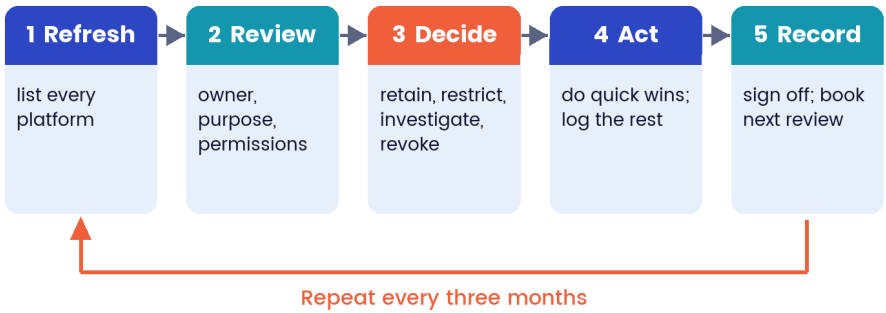
CHAPTER 11

# The Quarterly Connected-App Audit



This is the centre of the book. The quarterly audit is a short, repeatable review that keeps your list of connections accurate and your permissions proportionate. It needs no special software: a printed worksheet or a spreadsheet is enough.

**How long does it take?** For a small business with a few platforms and a modest number of integrations, a review typically takes **about 30 to 60 minutes**, depending on how many systems and connections you have. The first time, building the inventory takes longer; Chapter 12 allows for that.




The quarterly cycle: refresh the list, review, decide, act, record. Then diary the next one.

## The seven-step quarterly routine

| Step | What to do | Typical time |
|---|---|---|
| **1. Prepare** | Open last quarter's inventory and the worksheet (Appendix A). Make sure the reviewer can see each platform's connected-app list | 5 minutes |
| **2. Refresh the list** | For each platform, view its connected apps. Add new ones. Mark any that have gone | 10 to 15 minutes |

| Step | What to do | Typical time |
|---|---|---|
| **3. Check purpose and owner** | Every app needs a purpose, a data description and a current, still-employed owner | 5 to 10 minutes |
| **4. Review permissions** | Read the granted permissions for each new or changed app, and for any flagged last time | 5 to 15 minutes |
| **5. Score and decide** | Use the risk-scoring table (Appendix C), then choose retain, restrict, investigate or revoke | 5 to 10 minutes |
| **6. Act and log** | Do quick removals now; put the rest on the action tracker with a date | 5 to 10 minutes |
| **7. Sign off** | Review lead and business owner sign; set the next date | 2 minutes |

## The resources

The audit uses seven forms. All are in the appendices and can be copied.

- **Quarterly audit checklist** (Appendix A, Part 1)
- **App inventory worksheet** (Appendix A, Part 2, with the template in Appendix B)
- **Permissions review worksheet** (Appendix A, Part 3)
- **Risk-scoring table** (Chapter 5 and Appendix C)
- **Decision log** (Appendix A, Part 4)
- **Action tracker** (Appendix A, Part 5)
- **Review sign-off** (Appendix A, Part 6)

The inventory uses these twelve fields: application name; connected business account; business purpose; data accessed; permissions granted; business owner; date approved; last reviewed; risk rating; decision (retain, restrict, investigate or revoke); action required; target completion date. For readability on a printed or small screen page, the templates show them as two linked tables.

## Worked example: a fictional company with five connected apps

> **Fictional example.** *Tidewater Advisory is a fourteen-person accountancy and advice firm. Every name and detail here is invented. It carries out a quarterly review on 5 November 2026. Two of its older apps were last checked in August; the rest have never been reviewed.*

**Inventory, part 1: what is connected**

| # | Application | Connected business account | Business purpose | Data accessed | Permissions granted | Business owner |
|---|---|---|---|---|---|---|
| 1 | SlotPilot | Google Workspace calendar (office) | Client booking page | Event times and attendee names | Read and create events on one calendar | Office Manager |
| 2 | ClauseNote | Microsoft 365 calendar and OneDrive | AI meeting summaries | Meeting content, client discussions, files the user can reach | Read calendar; read all files the user can access | Practice Manager |
| 3 | FlowLink | Email, CRM and shared drive | Automates client onboarding | Client details, emails, documents | Send email; read and write CRM; read and write files | Operations Lead |
| 4 | QuickInvoice | Accounting system and one drive folder | Issues invoices | Customer names, addresses, amounts | Read and write invoices; read one folder | Finance Lead |
| 5 | OldCRM Sync | Practice mailbox and contacts | Sync built by a former contractor | All mail and contacts | Read and write mail and contacts; delete | **None (contractor left)** |

## Inventory, part 2: the review

| # | Date approved | Last reviewed | Risk rating | Decision | Action required | Target date |
|---|---|---|---|---|---|---|
| 1 | 12 Mar 2025 | 5 Aug 2026 | **Low** (7) | Retain | None; confirm at next review | 4 Feb 2027 |
| 2 | 3 Jun 2026 | Never | **Medium** (10) | Restrict | Remove file access; read its data-retention terms; check for a DPA | 19 Nov 2026 |
| 3 | 21 Sep 2025 | Never | **High** (11) | Restrict | Move to a dedicated service account; limit to onboarding folder; list all flows; delete unused ones | 26 Nov 2026 |
| 4 | 8 Jan 2024 | 5 Aug 2026 | **Medium** (8) | Retain | Put the vendor's DPA on file | 30 Nov 2026 |
| 5 | 14 Feb 2023 | Never | **Critical** (14) | Revoke | Check last 90 days of activity; revoke; test mail and contacts; ask the vendor to delete data | 9 Nov 2026 |

**Scoring for the five** (sensitivity, breadth, power, necessity, assurance gaps): SlotPilot 2+1+2+1+1 = 7. ClauseNote 3+2+1+2+2 = 10. FlowLink 3+3+2+1+2 = 11. QuickInvoice 3+1+2+1+1 = 8. OldCRM Sync 3+2+3+3+3 = 14.

## Decision log

| Date | App | Decision | Reason | Decided by | Evidence checked |
|---|---|---|---|---|---|
| 5 Nov 2026 | OldCRM Sync | Revoke | No owner; unused; can delete mail; contractor gone | Practice Manager | Permissions screen; activity log |
| 5 Nov 2026 | FlowLink | Restrict | Needed, but broad access across three systems | Operations Lead | Flow list; permissions screen |
| 5 Nov 2026 | ClauseNote | Restrict | Useful; file access not needed for summaries | Practice Manager | Permissions screen; vendor terms |

## Action tracker

| # | Action | Owner | Due | Status |
|---|---|---|---|---|
| 1 | Review 90 days of activity for OldCRM Sync, then revoke | IT support / Practice Manager | 9 Nov 2026 | Open |

| # | Action | Owner | Due | Status |
|---|---|---|---|---|
| 2 | Test mail and contact sync after revocation | Office Manager | 10 Nov 2026 | Open |
| 3 | Remove ClauseNote file access; check vendor terms | Practice Manager | 19 Nov 2026 | Open |
| 4 | Create FlowLink service account; narrow scopes; remove unused flows | Operations Lead | 26 Nov 2026 | Open |
| 5 | File QuickInvoice DPA | Finance Lead | 30 Nov 2026 | Open |

**Sign-off.** Reviewed by: Practice Manager, 5 Nov 2026 (46 minutes). Approved by: Managing Director. Next review: 4 February 2027.

In under an hour, Tidewater has an inventory where there was none, one removal it would not otherwise have made, three tightened permissions and a date in the diary.

## Making it stick

- **Book the next review before you leave the room.** A review without a date is a good intention.
- **Rotate the reviewer** occasionally, so that more than one person knows the process.
- **Review early after events.** A departure, an incident, a vendor announcing a breach or a change of ownership all justify a review sooner than the calendar says.
- **Keep the records.** Last quarter's worksheet is the quickest way to start the next.

## Takeaways

- **Seven steps, thirty to sixty minutes**, once the first inventory exists.
- **Twelve fields** per app are enough to make a defensible decision.
- **Decide, act, log, and diary the next date.**

CHAPTER 12

# Your 30-Day Connected-App Security Plan



This plan is for a business with little time and no security budget. It assumes one person leads, with support from whoever manages each system. Times are estimates and will vary with the number of systems you have.

| WEEK 1 Find | WEEK 2 Judge | WEEK 3 Tidy | WEEK 4 Systemise |
|---|---|---|---|
| Platforms and connected-app lists copied into an inventory | Permissions read, risks scored, priorities ranked | Remove or restrict; document decisions; DPAs on file | Policy adopted, owners named, quarterly review booked |
| **2 to 4 hours** | **2 to 3 hours** | **2 to 4 hours** | **1 to 2 hours** |

Four weeks: find, judge, tidy, and make it routine.

## Week 1: Find your platforms and connections

**Estimated time:** 2 to 4 hours, spread over the week.

**Tasks.**

1. List your business platforms (Chapter 7, Step 1), including accounts held by individuals.
2. For each, open the connected-app list and copy it into the inventory template (Appendix B).
3. Note the owner and purpose where known; leave the gaps blank.

4. Ask staff, in one short message, which tools they have connected to their accounts.

**Expected outcome.** A first inventory, however incomplete, and a clear view of the gaps.

**Completion checklist.**

- ☐ Platform list written down
- ☐ Connected-app lists copied from every platform
- ☐ Staff asked about tools they have connected
- ☐ Inventory started in a shared, access-controlled location

## Week 2: Review permissions and prioritise

**Estimated time:** 2 to 3 hours.

**Tasks.**

1. Read the permissions on each app and record them (Chapter 7, Step 5).
2. Score each connection with Appendix C.
3. Sort the list: Critical first, then High.
4. Identify the likely owner for each. Ask anyone whose name appears.

**Expected outcome.** A ranked list and a short set of priority items.

**Completion checklist.**

- ☐ Permissions recorded
- ☐ Risk ratings assigned
- ☐ Critical and High apps flagged
- ☐ Owners identified or confirmed missing

## Week 3: Remove, restrict and document

**Estimated time:** 2 to 4 hours.

**Tasks.**

1. Follow Chapter 8 for each unnecessary or suspect connection: check dependencies, record, revoke, verify, test.
2. Restrict the High-rated apps you are keeping (narrower scopes, service accounts).
3. Request vendor deletion of data where appropriate (Chapter 8).

4. Put a DPA on file for apps that process personal data (Chapter 9).
5. Log every decision.

**Expected outcome.** Fewer connections, narrower permissions, and a written record.

**Completion checklist.**

- ☐ Critical items resolved or escalated
- ☐ High items restricted, revoked or scheduled
- ☐ Workflows tested after changes
- ☐ Decision log completed
- ☐ Any deletion requests sent

## Week 4: Policy, ownership and the calendar

**Estimated time:** 1 to 2 hours.

**Tasks.**

1. Adapt the policy in Appendix F; put real names in the placeholders.
2. Assign an owner and deputy to every remaining connection.
3. Adopt the approval form (Appendix D) for new integrations.
4. Add connected apps to your leaver checklist.
5. Put the first quarterly review in the diary, with a reminder.

**Expected outcome.** A working policy, a named owner for everything, and the next review booked.

**Completion checklist.**

- ☐ Policy adapted and shared with staff
- ☐ Every connection has an owner and deputy
- ☐ Approval form in use
- ☐ Leaver checklist updated
- ☐ Next quarterly review in the diary

## Why small, repeated reviews work

A one-off clean-up helps, but it decays: new apps arrive, people move on, and permissions drift. A short review each quarter changes the slope. It will not make a business immune to every incident, and no checklist guarantees security or compliance. What it does is improve **visibility**: you know what is

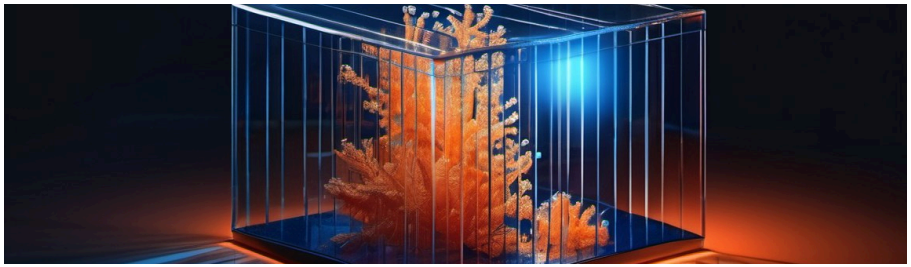
connected. It reduces **unnecessary exposure**: access that nobody needs is removed. And it builds **evidence**: you can show what you looked at and when.

For most small businesses, that is a large improvement for about an hour every three months.

## Takeaways

- **Four weeks, a few hours each:** find, judge, tidy, systemise.
- **Start with the inventory.** You cannot manage what you cannot see.
- **Book the second review before you finish the first.**

# Conclusion: Know Who Has the Keys



The central idea of this book fits on a card: **every connection has a purpose, an owner, a permission you understand and a review date.**

Connected apps are not the enemy. They make small businesses faster and more capable than they could otherwise afford to be. But convenience quietly accumulates access, and access without oversight is a risk that grows with every Monday-morning click.

You now have the vocabulary to read an approval screen, a yardstick to judge access, a method to remove it safely and a rhythm to keep the list honest. Remember the limits: a checklist does not guarantee security or compliance, revoking access does not delete what is already copied, and a risk rating is a screening aid, not a certificate.

If you do one thing after closing this book, open Appendix A, pick one platform and list its connected apps. Most people find at least one they had forgotten. That is not a failure. It is the review working.

## A note from the author, and where to go next

If you would like more practical privacy and data-protection resources for small businesses, including guides and tools on topics that this book only touches, such as DPAs, records of processing and breach response, you will find them on **GDPRGard.eu**, the companion resource for this book. The site's material is general information and does not replace advice on your own circumstances.

APPENDIX A

# Quarterly Connected-App Audit Worksheet

*Print this appendix or copy it into a document. It can be used on its own. Allow 30 to 60 minutes. Fill in one worksheet per quarter and keep it with your records.*

**Business:** _____ **Quarter / year:** _____ **Review date:** _____

**Reviewer:** _____ **Platforms reviewed:** _____

## Part 1. Quarterly audit checklist

- ☐ I have the previous quarter's worksheet and inventory open.
- ☐ I can see the connected-app list on every platform in scope.
- ☐ I added every new app found since last time to the inventory.
- ☐ I marked every app on the inventory that has now gone.
- ☐ Every app has a purpose, data description and permissions recorded.
- ☐ Every app has a named owner who still works here.
- ☐ I flagged apps with send, share, delete or administrator rights.
- ☐ I checked personal-account connections to business data.
- ☐ I looked at apps that touch personal data and checked for a DPA where needed.
- ☐ I scored every new, changed or flagged app (Appendix C).
- ☐ I decided retain, restrict, investigate or revoke for each flagged app.
- ☐ I completed quick removals and logged slower tasks.
- ☐ I recorded decisions in Part 4 and actions in Part 5.
- ☐ I signed off in Part 6 and booked the next review.

## Part 2. Working inventory

*Use this working table, then transfer details to the full inventory in Appendix B.*

| # | Application | Account connected | Owner | Permissions (summary) | Risk | Decision | Action and date |
|---|---|---|---|---|---|---|---|
| 1 | | | | | | | |

| # | Application | Account connected | Owner | Permissions (summary) | Risk | Decision | Action and date |
|---|---|---|---|---|---|---|---|
| 2 | | | | | | | |
| 3 | | | | | | | |
| 4 | | | | | | | |
| 5 | | | | | | | |
| 6 | | | | | | | |
| 7 | | | | | | | |
| 8 | | | | | | | |

*Risk: Low / Medium / High / Critical. Decision: Retain / Restrict / Investigate / Revoke.*

## Part 3. Permissions review

*For each flagged app (use the # from Part 2), answer Y (yes), N (no) or ? (unsure). Any N in the first three columns, or any ? , calls for a decision.*

| # | Needs this data? | Needs to change or delete? | Limited to selected resources? | Still used? | Owner and approver still here? | DPA or terms checked? |
|---|---|---|---|---|---|---|
| | | | | | | |
| | | | | | | |
| | | | | | | |
| | | | | | | |
| | | | | | | |

## Part 4. Decision log

| Date | App | Decision | Reason | Decided by | Evidence checked |
|---|---|---|---|---|---|
| | | | | | |
| | | | | | |
| | | | | | |
| | | | | | |
| | | | | | |

## Part 5. Action tracker

| # | Action | Owner | Due | Status (open / done) |
|---|---|---|---|---|
| | | | | |
| | | | | |
| | | | | |
| | | | | |
| | | | | |

## Part 6. Review sign-off

**Apps reviewed:** _____ **New since last review:** _____ **Revoked:** _____ **Restricted:** _____

**Time taken:** _____ minutes

**Reviewed by (name and role):**

_____

**Date:** _____

**Approved by (owner or director):**

_____

**Date:** _____

**Next review date:** _____

APPENDIX B

# Connected-App Inventory Template

*Copy these column headings into a spreadsheet, one row per connected app. The twelve fields are split across two tables so that they fit on a page. Use the same # in both.*

### Spreadsheet headings (copy and paste into row 1):

```
Application | Connected business account | Business purpose | Data accessed | Permissions granted | Business owner | Date approved | Last reviewed | Risk rating | Decision | Action required | Target completion date
```

## Part 1. What is connected

| # | Application name | Connected business account | Business purpose | Data accessed | Permissions granted | Business owner |
|---|---|---|---|---|---|---|
| 1 | | | | | | |
| 2 | | | | | | |
| 3 | | | | | | |
| 4 | | | | | | |
| 5 | | | | | | |
| 6 | | | | | | |

## Part 2. Review status

| # | Date approved | Last reviewed | Risk rating | Decision | Action required | Target date |
|---|---|---|---|---|---|---|
| 1 | | | | | | |
| 2 | | | | | | |
| 3 | | | | | | |
| 4 | | | | | | |
| 5 | | | | | | |
| 6 | | | | | | |

## Field guide

| Field | What to write |
|---|---|
| **Application name** | Exactly as shown in the platform's list |
| **Connected business account** | Which mailbox, drive, CRM or calendar, and whose |
| **Business purpose** | One sentence on why it exists |

| Field | What to write |
|---|---|
| **Data accessed** | What kinds of data it can reach (for example: client emails, invoices, contacts) |
| **Permissions granted** | The wording from the approval screen or admin console |
| **Business owner** | The named person responsible, with a deputy if possible |
| **Date approved** | When access was granted, if known |
| **Last reviewed** | Date of the last audit |
| **Risk rating** | Low, Medium, High or Critical (Appendix C) |
| **Decision** | Retain, restrict, investigate or revoke |
| **Action required** | The specific next step, or "none" |
| **Target completion date** | When it will be done |

**Keep the inventory safe.** It lists where your data lives and what can reach it. Store it where only the people who need it can open it.

APPENDIX C

# Permission Risk Assessment

*A practical screening method for small businesses. It is not a formal security certification, audit or standard, and it does not replace professional assessment of high-risk systems.*

## How to score

Score each connection from 1 to 3 on five factors, then add the numbers (range 5 to 15).

| Factor | 1 | 2 | 3 |
|---|---|---|---|
| **A. Data sensitivity** | Little or none | Internal business information | Personal, financial, confidential data or credentials |
| **B. Breadth of access** | One folder, calendar or record type | A whole mailbox, drive or system | Many users or the entire organisation |
| **C. Ability to change** | Read-only | Create, edit or send | Delete, share externally, manage permissions or administer |
| **D. Business necessity** | Essential and regularly used | Useful but replaceable | Rarely used, or nobody can say why |
| **E. Assurance gaps** | Known supplier, named owner, terms reviewed | Some gaps (no recent review, unclear data terms) | Unknown supplier, no owner or never reviewed |

## Rating bands

| Total | Rating | Normal response |
|---|---|---|
| 5 to 7 | **Low** | Retain; check at the next quarterly review |
| 8 to 10 | **Medium** | Retain or restrict; confirm owner and purpose |
| 11 to 13 | **High** | Restrict, investigate or revoke this month |
| 14 to 15 | **Critical** | Investigate and likely revoke now |

**Override.** If B and C both score 3, rate the connection at least High.

## Context that can raise the rating

Add a note, and consider moving up a band, where any of these apply:

- the app can reach special-category or other highly sensitive personal data;
- it is connected to an administrator's or director's account;
- it was authorised through a personal account on business data;
- the vendor has recently changed ownership or announced a security incident;
- the app can send messages in your name to customers;
- the data may be stored in a country you have not checked.

## Scoring sheet

| App | A | B | C | D | E | Total | Rating | Override or note |
|---|---|---|---|---|---|---|---|---|
| | | | | | | | | |
| | | | | | | | | |
| | | | | | | | | |
| | | | | | | | | |
| | | | | | | | | |

APPENDIX D

# New Integration Approval Form

*Complete before anyone authorises a new application against business data. Keep the completed form with your inventory.*

**Requested by:** _____ **Date:** _____ **Proposed business owner:** _____

## 1. The request

**Application and supplier name:**

_____

**What business problem does it solve?**

_____

_____

**Which account or system will it connect to?**

_____

**Is this a business account? (Not a personal one)** Yes / No

## 2. What it will access

**Data it will see or change:**

_____

**Does that include personal data about customers, staff or others?** Yes / No / Unsure

**Permissions requested (copy the wording shown):**

_____

_____

## 3. The seven questions

| Question | Answer |
|---|---|
| Does the app need access to this data? | |
| Does it need to modify or delete? | |

| Question | Answer |
|---|---|
| Does it need the whole account, or only selected resources? | |
| Is each permission needed for the feature we will use? | |
| Could a less powerful option do the job? | |
| Who will own it, and who is the deputy? | |
| What happens when the owner leaves or the project ends? | |

## 4. The supplier

- ☐ I found the supplier's privacy policy and security information.
- ☐ I know where the supplier stores the data (country or region).
- ☐ A data processing agreement is available, signed or not needed (explain): _____
- ☐ I know how to request deletion of our data.
- ☐ I know how to remove the app's access.

## 5. Decision

**Risk rating (Appendix C):** Low / Medium / High / Critical (score _____)

**Decision:** Approve / Approve with limits / Refuse

**Limits or conditions:**

_____

**Review date:** _____

**Approved by:** _____ **Date:** _____

APPENDIX E

# Emergency Access Review Checklist

*For use when something looks wrong, or when a change forces an unplanned review. If you have an IT or security provider, contact them early. This checklist supports an incident process; it does not replace one.*

## Section 1. Suspected compromise or unexpected activity

- ☐ Note what you saw, with date and time. Take screenshots before changing anything.
- ☐ Tell your named incident contact and your IT or security provider.
- ☐ Do not delete messages, logs or app entries until they are recorded.
- ☐ List every connected app on the affected account.
- ☐ Identify apps with send, share, delete or administrator rights.
- ☐ Check recent activity and audit logs where your platform offers them.
- ☐ Revoke access for any app that is unknown or clearly unnecessary, noting what you remove.
- ☐ Reset the affected account's password and review sign-in security (this alone will not remove an app's authorisation).
- ☐ Rotate API keys, passwords or secrets that the app or its data may have exposed.
- ☐ Check for unfamiliar mail rules, forwarding or sharing links.
- ☐ Decide whether personal data may have been accessed, and start your breach assessment (Chapter 9).
- ☐ Record the timeline and actions taken.
- ☐ UK organisations: consider the NCSC's advice for small organisations and the gov.uk/report-cyber signposting service.

## Section 2. Employee departure

- ☐ Identify every app the person owns or approved.
- ☐ Reassign each to a named person, or revoke it.
- ☐ Move automations and integrations from personal logins to service accounts.
- ☐ Check apps connected through their personal account to business data.
- ☐ Remove their access to the platforms' admin consoles.

- ☐ Update the inventory.

## Section 3. Discovery of an unnecessary high-risk integration

- ☐ Record its name, purpose (if known), account, permissions and approval date.
- ☐ Find out who approved it and who uses it.
- ☐ Check its recent activity for anything unexpected.
- ☐ Check what would stop working if it were removed.
- ☐ Revoke, verify, test and document (Chapter 8).
- ☐ Request deletion of data held by the supplier if appropriate.
- ☐ Add the lesson to the next quarterly review.

## Section 4. Supplier announces a breach or change of ownership

- ☐ Find the supplier's notice and note the date.
- ☐ Identify which of your connections to the supplier exist.
- ☐ Follow the supplier's instructions to revoke, rotate or reconnect.
- ☐ Review activity logs for the period named in the notice.
- ☐ Assess any impact on personal data and record your decision.

APPENDIX F

# Small Business Connected-App Policy

*Copy into a document, replace everything in [square brackets], delete what does not apply, and have the owner or director approve it. This template is general guidance, not legal advice.*

**[Business name] Connected-App Policy**

**Version:** [1.0] **Effective date:** [date] **Policy owner:** [name and role] **Next review:** [date]

**1. Purpose.** This policy sets out how [Business name] approves, records, reviews and removes third-party applications and integrations that can access our business systems and data.

**2. Scope.** It applies to all staff, contractors and volunteers, and to these systems: [email, calendar, cloud storage, CRM, accounting, HR, helpdesk, project tools, automation tools, AI tools, other].

**3. Who may authorise.** Nobody may connect a third-party application to a business account or business data without approval from [approver name or role]. For apps that reach personal data, administrator rights or the whole organisation, approval also requires [second approver or director].

**4. Approval process.** The requester completes the New Integration Approval Form. The approver considers the seven questions of least privilege and records a risk rating. We aim to respond within [number] working days.

**5. Permission scopes.** We approve the narrowest access that delivers the business purpose. Requests for "all files", full mailbox, delete, share or administrator rights need a written justification.

**6. Personal data.** Before an app that processes personal data is approved, we check the supplier's data-protection terms, where the data is stored and how deletion is requested. A data processing agreement is put on file where required. [Data protection lead] advises on questions.

**7. Personal accounts.** Business data must not be connected to apps through personal accounts. Business accounts must not be used to sign in to unapproved apps.

**8. Records and ownership.** Every approved connection is recorded in the inventory with: purpose, data accessed, permissions, business owner and deputy, approval date and risk rating. The inventory is held at [location] and maintained by [name].

**9. Connections must have an owner.** An app without a named, current owner will be restricted or revoked.

**10. Employee departures.** Before an employee, contractor or volunteer leaves, [manager] ensures every connection they own or approved is reassigned or revoked, and the inventory is updated.

**11. Emergency revocation.** [Names or roles] may revoke any connection immediately if they suspect compromise, misuse or unnecessary high-risk access. They must tell [policy owner] as soon as practicable and record the action.

**12. Review.** We review all connections every [three months] using the Quarterly Connected-App Audit Worksheet, and after any security incident, major supplier change or the departure of a connection owner.

**13. Incidents.** Suspected misuse is reported to [name/contact] immediately and handled under our incident process, including assessment of whether personal data has been affected.

**14. Exceptions and escalation.** Exceptions must be in writing, time-limited, approved by [director] and recorded. Questions or disagreements are escalated to [role].

**15. Consequences.** Breaches of this policy may be handled under [disciplinary or contractual procedures].

**Approved by:** [name, role] **Date:** [date]

APPENDIX G

# Glossary

| Term | Plain-English meaning |
|---|---|
| **Access token** | A short-lived digital credential that an app presents to a platform to prove it has permission to act. |
| **Administrator consent** | Approval of an app's access granted by an administrator on behalf of the organisation, rather than by one user. |
| **API** | Application programming interface: the defined requests one piece of software lets another make. |
| **Application-level (app-only) access** | Access in which an app acts as itself, not on behalf of a signed-in user. Often broader. |
| **Authentication** | Proving who you are, for example with a password or a prompt on your phone. |
| **Authorisation** | Deciding what an authenticated person or app is allowed to do. |
| **Automation platform** | A tool for connecting several apps so that actions in one trigger actions in others. |
| **Consent screen** | The window listing the permissions an app asks for before you click Allow. |
| **Controller** | The organisation that decides why and how personal data is processed. |
| **CRM** | Customer relationship management: the system holding customer and deal records. |
| **Data minimisation** | Processing only the personal data that is adequate, relevant and necessary for the purpose. |
| **Data processing agreement (DPA)** | A contract between a controller and a processor setting out how personal data may be handled. |
| **Delegated access** | An app acting on behalf of a signed-in user, limited to what that user can reach. |
| **Integration** | A connection between two pieces of software so that they can exchange information. |
| **Least privilege** | Giving only the minimum access needed to do the job, and no more. |
| **OAuth** | An internet standard that lets you authorise an app to use your data on another service without giving it your password. |
| **Permission scope** | A named permission, such as "read calendar", that defines what an app may do. |
| **Personal data** | Information relating to an identified or identifiable living person. |

| Term | Plain-English meaning |
|---|---|
| **Processor** | An organisation that processes personal data on behalf of a controller. |
| **Refresh token** | A credential that lets an app obtain new access tokens without asking you again. |
| **Revoke** | To withdraw an app's permission so it can no longer reach your data. |
| **SaaS** | Software as a service: software run by a provider and used online. |
| **Service account** | A non-personal account used by software to connect systems, so connections do not depend on one employee. |
| **Tenant** | An organisation's own account space with a cloud provider, such as a company's Microsoft 365 or Google Workspace environment. |
| **Third-party application** | Software made by a company other than you and the platform it connects to. |
| **Token** | A digital credential that stands in for a sign-in, used by apps to prove permission. |

APPENDIX H

# Knowledge Check

*Answer the ten questions, then check the answers below.*

**1. Which description of OAuth is most accurate?** A. A guarantee that any app using it is secure. B. A framework that lets you authorise an app to access your data without sharing your password. C. A type of antivirus programme. D. A password manager.

**2. What is the difference between authentication and authorisation?** A. They mean the same thing. B. Authentication is what an app may do; authorisation is who you are. C. Authentication proves who you are; authorisation decides what you may do. D. Authentication applies to email only.

**3. What does a refresh token allow an app to do?** A. Obtain new access tokens without asking the user again. B. Reset your password. C. Remove other apps. D. Encrypt your files.

**4. Which kind of permission most deserves a sharp question before approval?** A. Seeing free/busy times on one calendar. B. Reading one named document. C. Viewing a profile name. D. Deleting, sharing externally or administering across the organisation.

**5. After you revoke an app's access, what is true?** A. All data it has already copied is automatically deleted. B. It can no longer reach your data through that authorisation, but you may need to ask the vendor to delete data it holds. C. The vendor is legally obliged to apologise. D. Nothing changes until the token expires.

**6. What does "least privilege" mean?** A. Using the cheapest tools. B. Giving every user administrator rights. C. Granting only the minimum access needed for the job. D. Removing all integrations.

**7. A connected app made a large export from your CRM at 3 a.m. and you do not recognise it. What is this most likely to be?** A. Evidence that needs urgent investigation and escalation. B. A normal feature of every CRM. C. A risk to review at the next quarterly audit. D. Nothing, because exports are always safe.

**8. Why does changing a password not necessarily remove an app's access?** A. Passwords are never used. B. Apps are immune to security controls. C. The vendor changes it for you. D. The app holds its own authorisation,

which must be found and revoked.

**9. Under the UK GDPR, if a personal data breach is likely to create a risk to people, when should it be reported to the ICO?** A. Within one year. B. As soon as possible and, where feasible, within 72 hours. C. Only if a customer complains. D. Never, for small businesses.

**10. Which four decisions does the quarterly audit use?** A. Accept, ignore, delay, delete. B. Buy, rent, sell, scrap. C. Retain, restrict, investigate, revoke. D. Start, stop, pause, resume.

## Answers and explanations

| Q | Answer | Why |
|---|---|---|
| 1 | **B** | OAuth is an authorisation framework. It does not guarantee that an app is trustworthy (Chapter 2). |
| 2 | **C** | Authentication is who you are; authorisation is what you can do (Chapter 2). |
| 3 | **A** | A refresh token lets an app obtain fresh access tokens, so access can continue without new prompts (Chapter 2). |
| 4 | **D** | Delete, external-share and administrator rights carry the greatest potential for harm (Chapter 3). |
| 5 | **B** | Revoking stops future access; it does not remove copies already held (Chapter 8). |
| 6 | **C** | Least privilege limits damage by restricting access to what is needed (Chapter 5). |
| 7 | **A** | An unexplained large export is evidence rather than a mere risk; preserve logs and escalate (Chapters 6 and 8). |
| 8 | **D** | An app's authorisation is separate from your password and must be revoked directly (Chapter 6). |
| 9 | **B** | The ICO's guidance gives this timescale for breaches likely to create a risk to people (Chapter 9). |
| 10 | **C** | The audit decides whether to retain, restrict, investigate or revoke each connection (Chapter 11). |

# Appendix I: Sources and Further Reading

*Pages were opened and read on 28 October 2026 unless noted. Web pages change; confirm the current text before relying on a source. Where a date is given it is the publication or "last updated" date shown by the source.*


1. Internet Engineering Task Force (IETF), *RFC 6749: The OAuth 2.0 Authorization Framework*, October 2012. https://www.rfc-editor.org/rfc/rfc6749
2. IETF, *RFC 9700: Best Current Practice for OAuth 2.0 Security* (BCP 240), January 2025. https://www.rfc-editor.org/rfc/rfc9700
3. OWASP Cheat Sheet Series, *OAuth 2.0 Protocol Cheatsheet*. https://cheatsheetseries.owasp.org/cheatsheets/OAuth2_Cheat_Sheet.html
4. Google, *Share some access to your Google Account data with apps from other developers*, Google Account Help. https://support.google.com/accounts/answer/14012355
5. Google, *Control which apps access Google Workspace data*, Google Workspace Admin documentation. https://knowledge.workspace.google.com/admin/apps/control-which-apps-access-google-workspace-data
6. Google for Developers, *OAuth 2.0 Policies*. https://developers.google.com/identity/protocols/oauth2/policies
7. Microsoft Learn, *Overview of permissions and consent in the Microsoft identity platform* (page dated March 2025; updated June 2026). https://learn.microsoft.com/en-us/entra/identity-platform/permissions-consent-overview
8. Microsoft Learn, *Review permissions granted to enterprise applications* (page dated March 2025; updated February 2026). https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/manage-application-permissions
9. Microsoft Learn, *Detect and remediate illicit consent grants* (Microsoft Defender for Office 365; dated July 2026). https://learn.microsoft.com/en-us/defender-office-365/detect-and-remediate-illicit-consent-grants
0. Google Threat Intelligence Group, Google Cloud Blog, *Widespread Data Theft Targets Salesforce Instances via Salesloft Drift*, 26 August 2025, updated 28 August 2025. https://cloud.google.com/blog/topics/threat-intelligence/data-theft-salesforce-instances-via-salesloft-drift
1. National Cyber Security Centre (NCSC), *Small organisations guide to cyber security*. https://www.ncsc.gov.uk/collection/small-business-guide
2. NCSC, *Advice for sole traders and small organisations to respond to cyber attacks*. https://www.ncsc.gov.uk/section/respond-recover/sole-small
3. NCSC, *Supply chain security guidance*. https://www.ncsc.gov.uk/collection/supply-chain-security

4. NCSC, *Cloud security guidance*. https://www.ncsc.gov.uk/collection/cloud-security
5. Information Commissioner's Office (ICO), *A guide to data security*. https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/security/a-guide-to-data-security/
6. ICO, *Controllers and processors*. https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/controllers-and-processors/
7. ICO, *UK GDPR data breach reporting (DPA 2018)*. https://ico.org.uk/for-organisations/report-a-breach/personal-data-breach/
8. European Data Protection Board (EDPB), *Guidelines 07/2020 on the concepts of controller and processor in the GDPR*, final version, 7 July 2021. https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-072020-concepts-controller-and-processor-gdpr_en
9. UK GDPR, Article 28 (Processor), legislation.gov.uk. Article 28 was read; other article numbers cited in Chapter 9 are from the author's working knowledge of the GDPR and are listed for final checking. https://www.legislation.gov.uk/eur/2016/679/article/28
0. UK Government, *Report a cyber incident* signposting service, as referenced by the NCSC. https://www.gov.uk/report-cyber
1. National Institute of Standards and Technology (NIST), Computer Security Resource Center, *Least privilege*, Glossary (cites CNSSI 4009-2022 and NIST SP 800-53 Rev. 5). https://csrc.nist.gov/glossary/term/least_privilege

# About the Author

**Zirlandia Milkovic** writes practical, plain-English guides on privacy, data protection and working safely with AI for small businesses. She is the creator of **GDPRGard.eu**, a resource of privacy and data-protection tools and guides for small and medium-sized organisations.

Her books aim to give busy owners something they can use the same day: a checklist, a template, a clear next step.

*Visit GDPRGard.eu for additional privacy and data-protection resources.*